mandate

Security Self-assessment

Threat model, control assessment and residual risks

2026 FinTechathon Topic F: Agent Wallet

Mandate Labs

Nanyang Technological University, Singapore

Member	Role	Programme	Study year
Mengzhong Ma	Leader	Computational Finance	PhD, year 4
Sat Chidananda	Member	Computer Science	PhD, year 1
Vrushank Ajay Ahire	Member	Computer Science	PhD, year 1
Wilfried Ariel Mulyawan	Member	Computer Science	PhD, year 1

Mengzhong Ma	mengzhon001@e.ntu.edu.sg
Sat Chidananda	SAT001@e.ntu.edu.sg
Vrushank Ajay Ahire	vrushank001@e.ntu.edu.sg
Wilfried Ariel Mulyawan	wmulyawa001@e.ntu.edu.sg

Advisor: Bao Te, Nanyang Technological University.

Correspondence: Mengzhong Ma, team leader.

Member names, roles, programmes and study years reproduce the submitted registration record. The source registration files are not part of this public document.

Document revision: LaTeX revision 1, 20 October 2026.

Implementation reference: tested source commit

`29d10422954d36f0e37c2d89336986d10d014aba`

https://github.com/MandateLabs666/mandate-wallet

This is a testnet engineering document. Observed results, implementation assumptions and research extensions are identified separately. Preparing this document does not constitute an official competition submission.

Contents

1 Assessment scope and threat model 2

2 Financial controls and their assumptions 2

3 Control coverage and residual risk 3

4 Evidence interpretation and privacy 4

5 Findings, repairs and retained limitations 4

5.1 Authorization and swap-reference repairs 4

5.2 Canonical recovery and coverage corrections 5

5.3 Onboarding, recording and operational findings 5

6 Review evidence and release recommendation 5

1 Assessment scope and threat model

This author self-assessment covers the immutable procurement account, gateway and MCP integration, workspace/onboarding, evidence verifier and controlled evaluation. Independent static-tool results have a separate dated scope. Neither author triage nor automated analysis is an external human audit or certification. The accepted source snapshot passed the documented clean reproduction; later document-only changes do not change that code.[9, 10]

Protected assets are owner-controlled tokens, finite session permissions, connection/signing material, original purchase/transaction identity and the integrity of disclosed records. A hostile agent host can possess the session key, bypass its SDK, race calls and modify or suppress local state. It cannot forge the trusted owner's signature or corrupt an assumed-correct account/token transition. The owner must review administrative intent through a trusted interface. A same-user process or administrator can read the local session signer; file permissions do not prevent that threat.

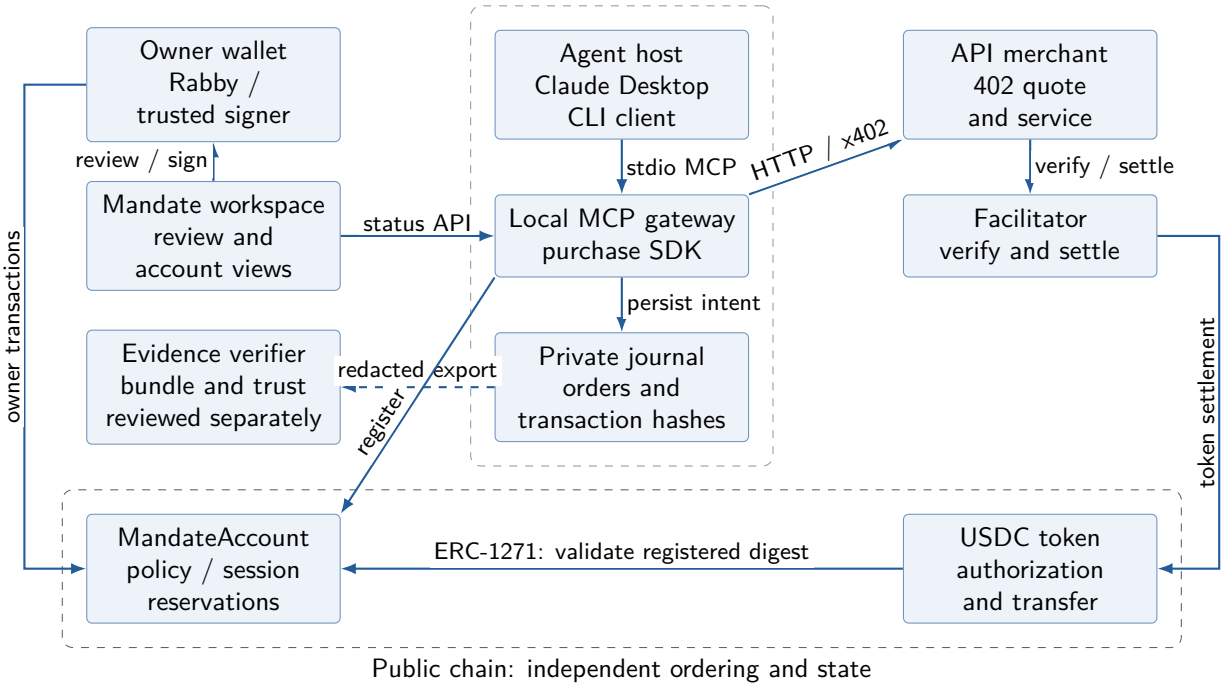


Figure 1: System architecture and the main data and authority paths. The dashed local-host region does not provide isolation against its administrator. Owner transactions and session-signed purchase operations carry different authority. The separate verifier needs an independently reviewed trust file.

2 Financial controls and their assumptions

The account fixes owner, asset, chain and token signing domain. Root and session scope constrain merchant, request, step, payee, amount, budget and expiry. Registration authenticates a complete typed payment, reserves both budgets atomically and permanently consumes the step. The account releases no token payment signature itself; the client waits for canonical registration before creating its token authorization. The selected token's actual settlement invokes ERC-1271 and reads live authority.[1, 4, 5, 13]

A previously successful facilitator precheck cannot override a later canonical revocation or version change. A payment already settled before revocation remains paid. Old session IDs cannot be

recycled. Policy replacement and pause/resume preserve occupancy and used steps rather than resetting spend authority.

Reservation is not token escrow. Paid, pending and uncertain commitments stay occupied; safe release requires strict expiry and an unused token nonce. A canceled or unexplained used nonce does not justify a refund. Owner withdrawal and independent roots can make authorized budgets exceed cash. Each chain is independent. Gas expense is separate from procurement and can accrue on failed transactions.

The token implementation is a critical assumption. Pinning its domain does not prevent a malicious proxy upgrade that preserves the domain. A generic EIP-3009 interface does not imply this particular account's ERC-1271 support. New asset/facilitator routes require direct compatibility evidence. Mainnet, Permit2, ERC-7710 and arbitrary Bazaar merchants are not accepted routes in this release.

3 Control coverage and residual risk

Threat	Implemented control / observed evidence	Residual boundary
Arbitrary session payment	Registered-digest-only validator, exact signed context, invalid-input and direct-signer tests	Owner compromise, token behavior and cryptographic assumptions remain.
Concurrent overspend	Atomic root/session reservation; different senders competing for a 0.15 budget	Failed gas and honest relayer nonce conflicts can still occur.
Duplicate purchase	Permanent used step, deterministic business nonce and durable original operation	Distinct owner-approved step IDs can represent similar real-world purchases.
Stale authority	Version/epoch/expiry and revocation checked at actual settlement	Canonically earlier payment cannot be reversed.
Malicious catalog / quote	Approved request, asset, network, recipient and amount checks; bounded network policy	An approved merchant can withhold data or supply false content.
Paid service failure	Separate payment/delivery/result states; same-order recovery	No automatic refund or guaranteed availability.
RPC timeout / reorg	Pre-broadcast journal, canonical hash/event reconciliation, original-operation restoration	Trusted-provider faults, deep reorg and prolonged outage can remain unresolved.
Evidence alteration	Salted commitments, signatures, previous-root links, ActionProof and separate verifier	A hostile signer can invent a fresh internally consistent observation.
Tail suppression	Compare export against separately trusted retained latest root	Unknown unanchored tail and common-host deletion remain outside detection.
Grinding / hidden calls	Finite owner envelope, durable idempotency and controller query cap	Calls outside the controller are not globally limited or observed.

Threat	Implemented control / observed evidence	Residual boundary
Host / key exposure	Owner key stays external; role separation and restricted runtime files	Same-host administrator isolation is not provided.
Credential export	Redacted schemas, safe diagnostics and actual-private-value package scans	New formats, contextual inference and publication mistakes require renewed review.

4 Evidence interpretation and privacy

An evidence signature authenticates the signer's statement, not an HTTPS transcript. A merchant receipt covers only its actual signed fields. In the implemented schema it does not cover payment amount, request body or result body. Financial transfer evidence and explicit disclosed-result checks supply different facts. The optional TLSNotary test concerns a separate public API and same-host notary/prover, not the controlled paid merchant.[12, 14]

The verifier checks a public bundle against a separately reviewed trust file. The required financial checks can pass while overall remains incomplete. Hidden result content cannot be declared valid. A valid prefix without an independent latest root cannot prove that no later checkpoint was hidden. Public amount, recipient and timing remain observable, so selective disclosure is not a general privacy or anonymity guarantee.

The gateway exposes fixed-profile MCP tools and does not load the owner key. Connection authentication does not grant on-chain authority. Rotating a token or reinstalling a connector does not revoke an already authorized payment. Standard host tool approvals also do not replace owner scope. The current transport is local stdio and loopback services rather than a production multi-tenant custody API.[9, 11]

5 Findings, repairs and retained limitations

5.1 Authorization and swap-reference repairs

SA-01 concerns the original Echo bearer-style credential. Echo v2 replaces it with role-separated EIP-712 signatures bound to the final UserOperation, chain, account, EntryPoint, implementation and policy/session context. Old bearer credentials are not silently migrated.

SA-02 concerns inconsistent swap ABI/decoder behavior and validation-time spending. The repaired route restricts the selected Uniswap ABI, execution mode and native value, uses exact input allowance with cleanup, records actual swap input in execution, and distinguishes outer transaction success from UserOperation success. Strict Alto and EntryPoint v0.7 evidence is separate from local tests. Validation simulation restrictions motivate the validation/execution split.[2, 3]

SA-03 concerns Echo encrypted signer storage. A local probe showed that truncated GCM tags were accepted. The repair requires the complete 16-byte tag and rejects truncated forms before decrypting. This demonstrates a repaired integrity-format weakness, not demonstrated key extraction or arbitrary on-chain authority. The full before/after record is retained in the source security review.

5.2 Canonical recovery and coverage corrections

SA-04 concerns reorg recovery retaining stale transaction or service observations. Canonical block-hash reconciliation and restored original operations preserve transaction identity; outcome evidence is appended after the newly canonical payment. Old evidence remains available.

SA-05 concerns an invariant-test handler that previously returned before exercising settlement. Independent actual-balance/reservation checks and a settlement regression correct the coverage. This is a test-harness correction rather than a new deployed-contract repair. Current invariant counts must not be attributed to the earlier incomplete harness.

SA-06 concerns malformed private JSON leaking parser fragments. Startup and public diagnostic paths now return safe codes. Subprocess canaries exercise the boundary. Public exports omit raw signed transactions, registration/payment payload signatures and private results unless an approved public-data summary explicitly permits them.

5.3 Onboarding, recording and operational findings

SA-07 concerns stale guide progress, hidden Local/Testnet choices, profile selection, broken workspace links and graphical connection binding. Independent profiles, progress-only reset, corrected routing and Guided packages have regressions and a later native Claude/Rabby run. Resetting the guide preserves chain authority and does not restore a revoked session.

SA-08 concerns recording-time RPC uncertainty and an expired unpaid commitment. Bounded original-hash rechecks, read-only reconciliation and stage-specific safe diagnostics improve handling. An explicitly approved replacement ETH task reused the same account and funds. Extending a session does not extend the account's immutable 300-second payment window. The exact original transport cause is not retrospectively asserted.

SA-09 remains open: same-host administrator access, controller bypass, unknown evidence tails, signed independent installation/updates and persistent local-node recovery. The workspace verification button also lacked a trusted profile during recording; the public financial report came from the standalone verifier. These are explicit release boundaries rather than passed checks.

6 Review evidence and release recommendation

The original M7 static-tool scope triaged 113 initial signals, with 112 remaining after the GCM repair. Later source revisions retained their own rechecks, including a purchase-feedback scope with 115 raw signals. These are reviewed findings, not a clean-scan label. The reports identify source hashes, actual tool completion, dispositions and limits. No external human audited the complete current product.

The controlled evaluation reports 120 eventual HTTP tasks, 132 settlements without duplicate payment and 10000 explicitly invalid calls with six legal controls. Stateful tests exercise important boundaries; finite tests do not prove universal exploit resistance.[7, 8] The clean source reproduction reports 50 Solidity cases, 153 TypeScript tests and the local paid-failure/recovery/revocation demo.[10]

The native Base Sepolia case pays 0.01 test USDC once, recovers the same order and rejects a new step after owner revocation without a new transaction. Required financial checks pass, while independent HTTPS provenance and complete history remain incomplete.[6]

This release is suitable for scoped testnet evaluation with trusted owner review and limited test assets. Production use requires independent human audit, stronger signing/retention isolation,

tested operational recovery, signed distribution and broader compatibility coverage. No mainnet operation or official competition submission is implied by this assessment.

References

[1] Remco Bloemen, Leonid Logvinov, and Jacob Evans. EIP-712: Typed structured data hashing and signing. https://eips.ethereum.org/EIPS/eip-712, 2017. Accessed 20 October 2026.

[2] Vitalik Buterin, Yoav Weiss, Dror Tirosh, Shahaf Nacson, Alex Forshtat, Kristof Gazso, and Tjaden Hess. ERC-4337: Account Abstraction Using Alt Mempool. https://eips.ethereum.org/EIPS/eip-4337, 2021. Mandate's Echo reference pins EntryPoint v0.7; the current standard page may describe later variants. Accessed 20 October 2026.

[3] ERC-7562 contributors. ERC-7562: Account Abstraction Validation Scope Rules. https://ercs.ethereum.org/ERCS/erc-7562, 2023. Accessed 20 October 2026.

[4] Francisco Giordano, Matt Condon, Philippe Castonguay, Amir Bandeali, Jorge Izquierdo, and Bertrand Masius. ERC-1271: Standard Signature Validation Method for Contracts. https://eips.ethereum.org/EIPS/eip-1271, 2018. Accessed 20 October 2026.

[5] Peter Jihoon Kim, Kevin Britz, and David Knott. ERC-3009: Transfer With Authorization. https://eips.ethereum.org/EIPS/eip-3009, 2020. Accessed 20 October 2026.

[6] Mandate Labs. Native Claude Desktop, Rabby and Base Sepolia execution evidence. https://github.com/MandateLabs666/mandate-wallet/tree/29d10422954d36f0e37c2d89336986d10d014aba/competition/video/claude-desktop-base-v1/execution-evidence, 2026. Recorded 19 October 2026; public evidence, trust configuration and source fingerprints.

[7] Mandate Labs. M7 benchmark protocol, raw-data audit and acceptance. https://github.com/MandateLabs666/mandate-wallet/blob/29d10422954d36f0e37c2d89336986d10d014aba/planning/M7_BENCHMARK_ACCEPTANCE.zh-CN.md, 2026. Protocol mandate-m7-r2; 120 HTTP tasks.

[8] Mandate Labs. M7 formal properties, counterexamples and guarantee boundaries. https://github.com/MandateLabs666/mandate-wallet/blob/29d10422954d36f0e37c2d89336986d10d014aba/planning/M7_FORMAL_BOUNDARIES.zh-CN.md, 2026. Manual arguments; not a machine-checked proof. Historical task-status statements retain their original date.

[9] Mandate Labs. Mandate Wallet: tested source snapshot. https://github.com/MandateLabs666/mandate-wallet/tree/29d10422954d36f0e37c2d89336986d10d014aba, 2026. Source commit 29d10422. Accessed 20 October 2026.

[10] Mandate Labs. Clean-source reproduction and publication records. https://github.com/MandateLabs666/mandate-wallet/tree/a0156351bb2b0eca183c58b3071a3aae52cdbb94/artifacts/competition/source-delivery/submission20261020, 2026. 16 phases, 50 Solidity cases and 153 TypeScript tests; source commit 29d10422.

[11] Model Context Protocol contributors. Model Context Protocol Specification. https://modelcontextprotocol.io/specification/2025-11-25, 2025. Protocol reference dated 2025-11-25; repository pins SDK 1.27.1. Accessed 20 October 2026.

[12] TLSNotary contributors. TLSNotary documentation: Introduction. https://tlsnotary.org/docs/intro/, 2026. Accessed 20 October 2026.

[13] x402 contributors. Wallet Compatibility. https://docs.x402.org/advanced-concepts/wallet-compatibility, 2026. Accessed 20 October 2026; actual token and facilitator behavior must be tested.

[14] x402 contributors. Signed Offers and Receipts. https://docs.x402.org/extensions/offer-receipt, 2026. Accessed 20 October 2026.